PORTFOLIO · FULL-STACK WEB / SECURITY

# Scriptorium 패스키 기반 창작 글쓰기 플랫폼

시·수필·소설 작성 + 시리즈 공개용 웹 에디터 · 초대제 · 패스키 전용 로그인(비밀번호 없음)
백엔드·배포·운영 직접 개발, 프론트엔드 AI 활용

| 서비스 | 기간 · 역할 | 규모 | 배포 |
|---|---|---|---|
| scriptorium.doyoulike.xyz | 2026.07 - 현재 · 1인 | Go 약 6,900줄 · 테스트 75개 | kctl · k3s · v0.16.x |

Go net/http · WebAuthn (go-webauthn) · SQLite (modernc, CGO 없음) · bluemonday · zstd · TypeScript (strict) · contenteditable · CompressionStream · Cloudflare · FROM scratch

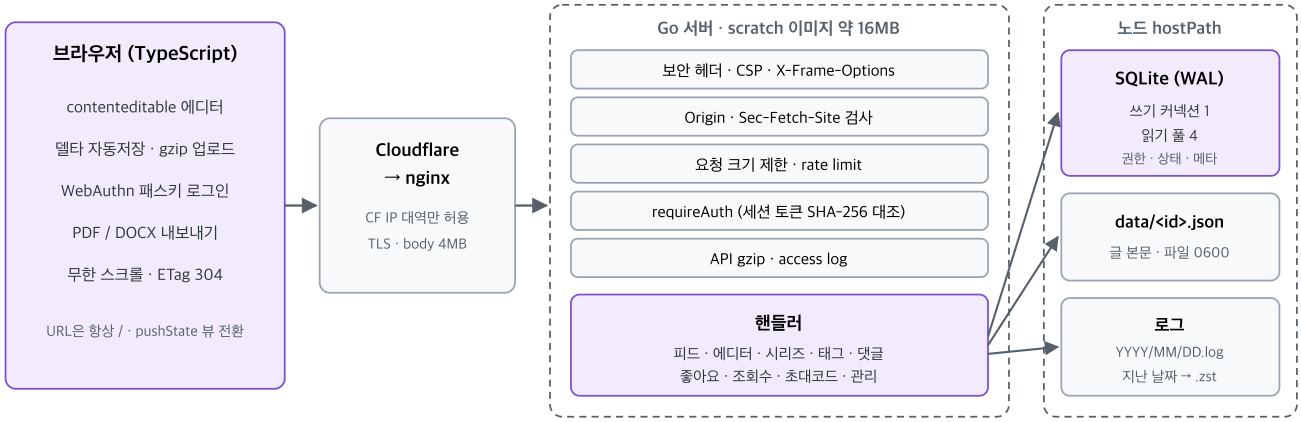
**AI 사용 범위** · 프론트엔드

---

## 개요

- 첫 화면 = 전체 사용자 공개 글 **피드** · 시리즈 글은 시리즈 카드로 묶음 · 작성자 클릭 → 작가 책장
- 글은 항상 비공개로 시작 · 에디터에서 공개 / 익명 공개 / 시리즈 / 태그 지정
- 프레임워크 없이 Go 표준 라이브러리 + TypeScript(strict, 번들러 없음) · 외부 CDN 요청 0 → CSP `script-src 'self'` 유지

## 아키텍처




요청 → 미들웨어 체인 순차 통과 · 권한·상태 = SQLite, 본문 = 파일 분리 저장 · 전 데이터 노드 hostPath 영속

## 주요 기능

### 인증과 가입

- 패스키(discoverable credential) 로그인 · 아이디 입력 불필요
- 가입 = 초대코드 필수 · 1코드 1계정 · 사용자 생성 트랜잭션 안에서 코드 소진 → 경쟁 상태 없음
- 다른 기기용 일회용 로그인 코드(6자리, 5분, 1회) · 계정당 패스키 여러 개 등록

### 에디터

- 글꼴(고딕/명조, 셀프호스팅), 크기, 서식, 제목, 인용, 목록, 링크, 글자색
- 입력 멈추면 자동저장 · 바뀐 구간만 보내는 델타 동기화
- PDF/DOCX 내보내기 브라우저 처리 · 서버 자원 사용 없음

### 읽기와 커뮤니티

- 공개 피드, 작가별 책장, 커서 기반 무한 스크롤
- 시리즈(드래그로 순서 지정), 자유 태그, 익명 공개
- 댓글, 좋아요, 조회수, 가독성 모드, 다크 모드, 모바일 반응형

### 운영

- 관리자 페이지: 초대코드 발급, 글 관리 · 관리자 지정은 CLI 전용
- 사용자 정보 포함 접근 로그 + 인증 이벤트 로그
- SQLite `.backup` 기반 백업 스크립트(무결성 검사, 14일 보관)

## 기술적 도전과 해결

### 01 피드 쿼리가 전체 글 수에 비례해 느려지던 문제

**문제**
- 페이지당 50편인데 1만 편 기준 45ms
- 댓글 수·좋아요 수·좋아요 여부 상관 서브쿼리 3개가 LIMIT 이전 전 행에서 실행
- 시리즈 총계용 윈도우 함수 → 전체 정렬 강제, 인덱스 조기 종료 불가 (EXPLAIN `USE TEMP B-TREE FOR ORDER BY` 2회)

**해결**
- 2단 구조: 안쪽에서 정렬·LIMIT으로 페이지 확정 → 바깥에서 51행 이하에만 집계 조인
- 시리즈 총계 = 페이지에 나온 시리즈만 별도 GROUP BY
- 피드 ETag 계산: OR 조건 분리 → 각각 인덱스 사용

**결과**
- 피드 1만 편 **45ms → 8.7ms (5.1배)** · ETag **6.2ms → 2.3ms (2.6배)**
- 2페이지부터 시리즈 총계가 줄던 잠재 버그 수정 · 정답 대조 테스트로 고정

### 02 긴 글 자동저장 트래픽: 델타 동기화

**문제**
자동저장마다 글 전체 전송 → 긴 글일수록 업로드 증가

**해결**
- 이전 본과 공통인 앞뒤 제외, 바뀐 구간만 전송
- UTF-16 단위 절단 + 서로게이트 쌍 경계 보정
- 서버 기준본 SHA-256 대조 · 불일치 시 412 → 클라이언트 전체 저장 폴백
- 4KB 초과 업로드 `CompressionStream` gzip · 서버 해제 크기 제한(zip bomb 방지)

### 03 HTML 정규화 최적화와 비가환성 발견

**문제**
저장마다 도는 `cleanHTML` (span 병합·정리) · 서식 많은 247KB 글 33ms

**발견**
- 순회 순서 변경으로 패스 축소 시도 → 출력 달라짐
- 퍼징으로 최소 반례 확보 → 규칙 적용 순서에 따라 결과가 바뀌는 비가환 구조 확인
- 해당 최적화 폐기, 이유는 코드 주석으로 기록

**해결**
- 출력 바이트 동일한 최적화만 채택
- 서식 없으면 파싱 생략 · 직렬화 후 재파싱 → DOM 복제 · 트리에서 떨어진 노드 스킵

**결과**
- 평문 46KB **1.0 → 0.2ms (4.6배)** · 서식글 247KB 33 → 24.8ms
- 랜덤 문서 **퍼징 20,000건** 기존 구현과 출력 전부 동일

### 04 보안 하드닝

**인증**
- 세션 토큰·로그인 코드 SHA-256 해시만 저장 → DB 유출돼도 재사용 불가
- 패스키 sign count 역행(복제 의심) 시 로그인 거부
- 로그인 코드 전체 IP 합산 실패 10회/분 차단

**요청**
- CSP 인라인 스크립트 금지 · 저장 HTML bluemonday 서버 정제
- 상태 변경 요청 Origin + `Sec-Fetch-Site` 검사
- 요청 크기 제한, IP당 rate limit, 서버 타임아웃 · 500 에러 상세는 서버 로그에만

**경로**
nginx에서 Cloudflare IP 대역만 허용 → 직접 접속 차단 · `CF-Connecting-IP` 위조 불가 → rate limit 실사용자 IP 기준

**의존성**
`govulncheck` 표준 라이브러리 취약점 11건 → Go 툴체인 업그레이드 → 재스캔 호출 취약점 0건

### 05 DOCX 폰트 임베드와 로그 아카이빙

**DOCX**
- 외부 라이브러리 없이 브라우저에서 zip + OOXML 직접 조립
- 실사용 글꼴만 ODTTF 난독화(ECMA-376 §17.8.1) 임베드 · zip 항목 deflate-raw 압축
- 폰트 3개 **7MB → 2.5MB** · 어느 기기에서도 나눔 서체 유지

**로그**
- 날짜별 `YYYY/MM/DD.log` · 지난 날짜 zstd 압축
- 압축본 끝까지 풀어 원본과 크기 일치할 때만 원본 삭제 → 중단돼도 유실 없음
- 실측 60MB 접근 로그 → 9.45MB · 표준 `zstd` CLI 해제 후 SHA-256 일치 확인

**전송**
- 폰트 TTF → WOFF2 · 10MB → 1.9MB
- 정적 자산 내용 해시 URL + 1년 immutable 캐시 · API gzip(피드 641B → 171B)

### 06 프론트엔드 TypeScript 전환 (JS 4,180줄, strict)

**문제** 전역 스코프 클래식 스크립트 3,600줄( `editor.js` ) · 서버 응답·DOM 타입 부재 → 리팩터링 시 필드 오타·null 접근을 런타임에서야 발견

**해결**
- 소스 `src/` → `static/*.js` 산출물로 분리 · `tsc` `outFile` 순서 이어붙임 → 번들러·모듈화 없이 기존 전역 구조 유지
- `editor.js` 를 최상위 문장 경계(TS 파서 기준)에서 9조각 분할 → 조각별 병렬 변환 후 교차 파일 타입 통합
- 서버 응답 interface 모델링 · 프로젝트 id를 서버 `int64` 에 맞춰 `number | null` 로 통일 · `any` 3곳
- Docker `web` (node) 스테이지에서 `tsc` 실행 → Go 빌드 스테이지로 복사 · 빌더 네이티브 아키텍처에서 1회만 실행

**결과** `tsc --noEmit` strict 오류 0건 · 원본 대비 전역 함수 이름 154개 동일 · 런타임 로직 변경 없음(타입 주석·캐스트만) · `go test` 통과

## 테스트와 검증

- Go 테스트 75개(17개 파일): 페이지네이션 누락·중복, 비공개·익명 노출 회귀, 피드 ETag 변화 감지 11종, 로그 압축 복구 등 · `go test -race` + 벤치마크 병행
- 읽기·쓰기 커넥션 분리 후 동시 읽기·쓰기 300회 무오류 · WAL로 자기 쓰기 즉시 읽힘
- Chrome DevTools Protocol 기반 브라우저 E2E 34건: 시리즈·태그 승계, 단축키, 사이드바 부분 갱신 등

| 5.1배 | 20,000건 | 10→1.9MB | 0건 |
|---|---|---|---|
| 피드 쿼리 (1만 편, 45→8.7ms) | 퍼징으로 확인한 출력 동일성 | 폰트 전송량 (WOFF2) | 호출되는 알려진 취약점 |